

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking

COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO2: Foot printing Tools: Conducting Competitive Intelligence, DNS Zone Transfers, Introduction to Social Engineering: Social Engineering Attacks and Countermeasures. (BT4)

Assessment Tool Weightage: 30%

Duration: 90 min

Total Marks: 50

Social Engineering Simulation

Questions

1. As a Security Analyst, perform an OSINT-based email enumeration assessment on the target domain **tesla.com** using **theHarvester** in Kali Linux. Collect publicly available email addresses, subdomains, hosts, and IP addresses associated with the organization. Categorize the discovered email addresses into likely roles such as Support, Sales, Human Resources, Administration, and Technical Teams. Analyze how the gathered information could assist an attacker during the reconnaissance phase and explain how it could be used for spear-phishing, credential harvesting, and impersonation attacks. Finally, recommend at least five countermeasures to reduce information leakage and social engineering risks, and submit a report with screenshots, commands executed, findings, risk analysis, and recommendations. **(20 Marks)**
2. As a cybersecurity awareness consultant, you are required to conduct a phishing awareness simulation using GoPhish and dummy employee accounts provided in the lab. Create an email template, launch a campaign, monitor user interactions, and generate a report showing delivery rate, email open rate, and click rate. Based on the results, provide recommendations to improve user awareness against phishing attacks.**(20 Mark)**.
3. Using **Nmap Aggressive Scan (-A)** on **scanme.nmap.org**, gather detailed information about the target including operating system details, open ports, and service versions. Assume you are an attacker and describe how the collected information could be leveraged to conduct a social engineering attack against the IT support team. Prepare a report explaining the attack methodology and defensive recommendations.**(10 Marks)**

Code of Conduct:

I Aluri Poojitha_____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

RUBRICS FOR CALCULATION

Social Engineering Simulation

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Social Engineering Scenario	20%	Demonstrates a comprehensive understanding of the social engineering scenario, attack techniques, and security context	Demonstrates good understanding with minor omissions.	Shows partial understanding but misses important aspects of the scenario.	Fails to understand or incorrectly interprets the social engineering scenario.
Identification of Attack and Vulnerabilities	20%	Correctly identifies the attack type, exploited vulnerabilities, and affected assets with complete accuracy	Correctly identifies most attack techniques with minor errors.	Identifies only some attack methods and vulnerabilities.	Unable to identify the attack type or associated vulnerabilities.
Application of Security Concepts and Countermeasures	25%	Effectively applies cybersecurity concepts and recommends appropriate preventive, detective, and corrective countermeasures	Applies relevant concepts with minor errors and recommends suitable countermeasures	Applies concepts partially with limited recommendations.	Unable to apply relevant cybersecurity concepts or recommend suitable countermeasures
Risk Analysis and Decision Making	20%	Performs logical risk analysis, evaluates business impact, and provides well-justified security decisions.	Provides reasonable analysis with adequate justification.	Performs limited analysis with weak justification.	Provides no meaningful analysis or justification
Clarity, Documentation and Technical Presentation	15%	Response is well-organized, technically accurate, professionally documented, and logically presented.	Response is clear with minor documentation or presentation issues.	Response lacks organization and contains technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.

QUESTION 1 :OSINT-Based Email Enumeration Assessment using theHarvester

Aim

To perform an Open Source Intelligence (OSINT) based email enumeration assessment on the target domain **tesla.com** using theHarvester in Kali Linux, identify publicly available email addresses, subdomains, hosts and IP addresses, analyze the risks associated with the collected information, and recommend suitable countermeasures against social engineering attacks.

Objective

- To perform OSINT reconnaissance using theHarvester.
- To collect publicly available email addresses, subdomains, hosts and IP addresses.
- To categorize the discovered email addresses into organizational roles.
- To analyze the security risks of publicly available information.
- To recommend countermeasures to reduce information leakage.

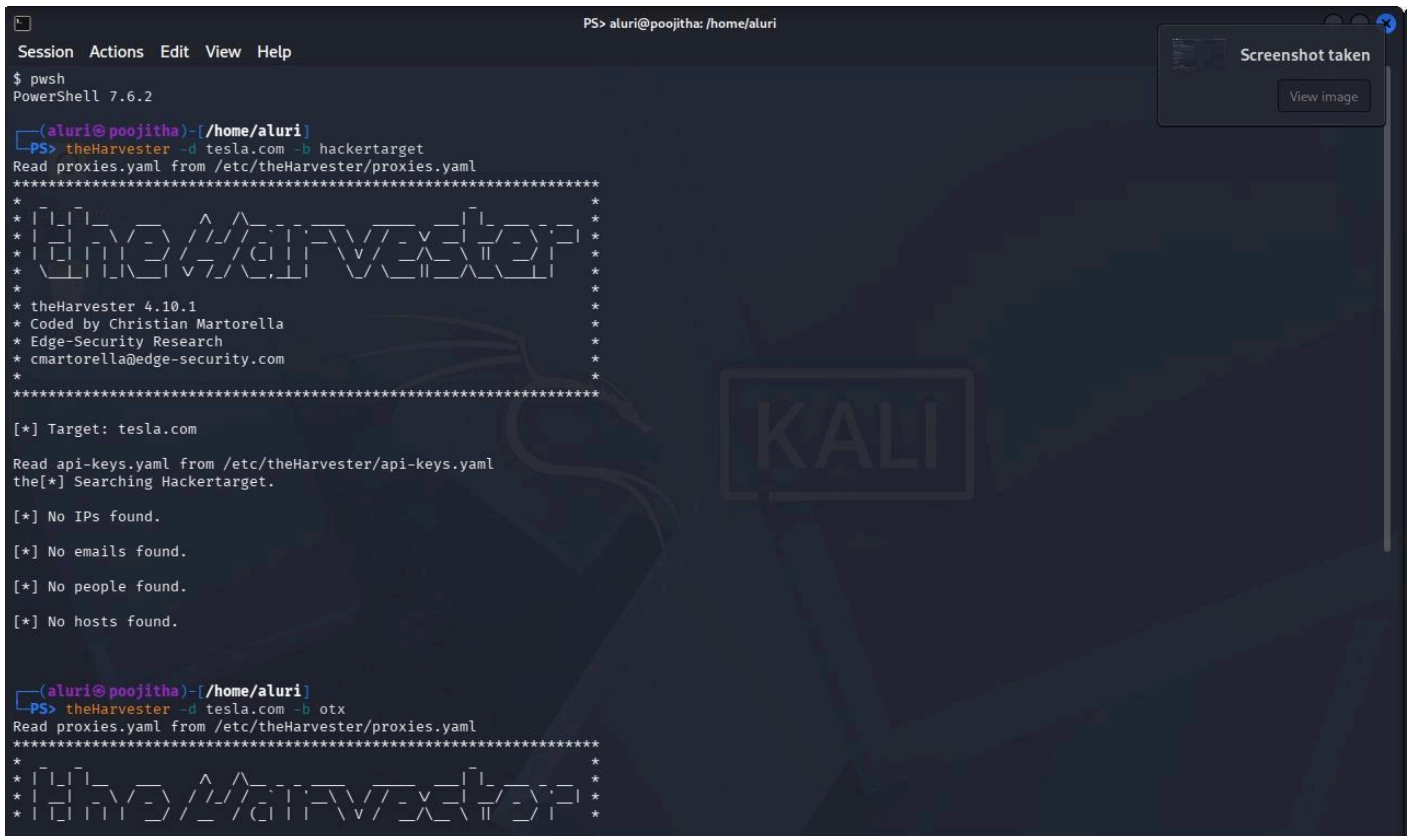
Tools Required

- Kali Linux
- theHarvester
- Internet Connection

Command Executed

```
theHarvester -d tesla.com -b hackertarget
theHarvester -d tesla.com -b otx
```

Screenshot 1



Procedure

1. Open the Kali Linux terminal.
2. Execute theHarvester using the target domain **tesla.com**.
3. Search using available OSINT sources.
4. Observe the results returned by the tool.
5. Record the discovered information.
6. Analyze the information from a security perspective.

Findings

TheHarvester searched the selected OSINT sources for publicly available information related to **tesla.com**.

Observed Output

Information	Result
Email Addresses	No public email addresses found
Subdomains	No subdomains found
Hosts	No hosts found
IP Addresses	No IP addresses found

Observation

The selected OSINT sources (`hackertarget` and `otx`) did not return any publicly available information for the target domain during the assessment. This may be due to source limitations, API restrictions, or the organization's security practices that minimize publicly exposed information.

Email Categorization

Since no public email addresses were discovered, no role-based categorization could be performed.

If such information had been available, the categories would include:

Category	Example
Support	support@tesla.com
Sales	sales@tesla.com
Human Resources	hr@tesla.com
Administration	admin@tesla.com
Technical Team	security@tesla.com

Risk Analysis

Even when little or no information is obtained, OSINT remains an important phase in cybersecurity assessments because attackers often combine results from multiple public sources.

Reconnaissance

Attackers use OSINT to understand an organization's infrastructure before launching an attack.

Spear-Phishing

If employee email addresses become publicly available, attackers can create personalized phishing emails that appear legitimate.

Example:

Dear Employee,

Your Tesla account requires password verification.

Click the following link to continue.

Such targeted emails increase the likelihood of user interaction.

Credential Harvesting

Attackers may create fake Tesla login pages and trick employees into entering usernames and passwords, allowing unauthorized access to systems.

Impersonation Attacks

Using publicly available information, attackers can impersonate:

- IT Support
- Human Resources

- Administration
- Technical Support

to deceive employees into revealing confidential information or installing malicious software.

Business Impact

Successful social engineering attacks can lead to:

- Credential theft
- Data breaches
- Financial loss
- Unauthorized system access
- Reputation damage

Countermeasures

1. Limit the publication of employee email addresses on public websites.
2. Use generic email addresses instead of individual employee addresses wherever possible.
3. Enable Multi-Factor Authentication (MFA) for all organizational accounts.
4. Configure email authentication mechanisms such as SPF, DKIM, and DMARC.
5. Conduct regular cybersecurity awareness and phishing awareness training for employees.
6. Periodically perform OSINT assessments to identify publicly exposed information.
7. Apply the principle of least privilege to restrict unnecessary access.

Result

The OSINT assessment was successfully conducted using **theHarvester** on the target domain **tesla.com**. The selected data sources did not reveal publicly available email addresses, hosts, subdomains, or IP addresses. This demonstrates that organizations can reduce information exposure by limiting publicly accessible data. The assessment also highlights how attackers could exploit any exposed information for reconnaissance, spear-phishing, credential harvesting, and impersonation attacks. Appropriate security controls such as multi-factor authentication, email security mechanisms, and employee awareness training can significantly reduce these risks.

QUESTION 2 :Phishing Awareness Simulation using GoPhish

Aim

To conduct a phishing awareness simulation using **GoPhish** with dummy employee accounts, monitor user interactions, analyze campaign statistics, and recommend security measures to improve employee awareness against phishing attacks.

Objective

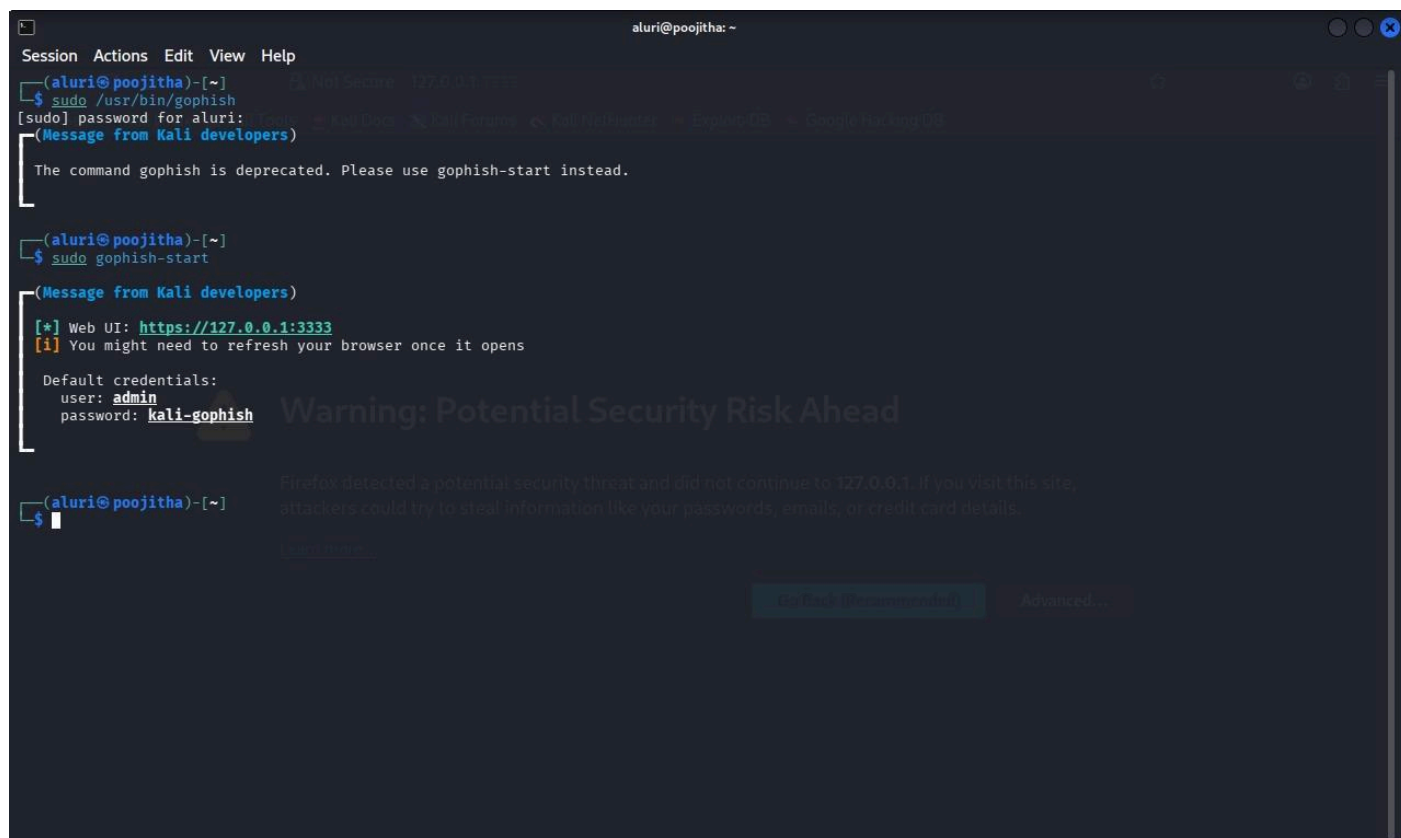
- To create a phishing email template.
- To launch a phishing awareness campaign.
- To monitor employee interactions.
- To generate campaign statistics.
- To recommend measures for improving phishing awareness.

Tools Required

- Kali Linux
- GoPhish
- Web Browser
- Dummy Employee Accounts

Command Executed

```
sudo gophish-start
```



```
aluri@poojitha: ~  
Session Actions Edit View Help  
[aluri@poojitha]-[~] Not Secure 127.0.0.1:3333  
$ sudo /usr/bin/gophish  
[sudo] password for aluri:   
(Message from Kali developers)  
The command gophish is deprecated. Please use gophish-start instead.  
[aluri@poojitha]-[~]  
$ sudo gophish-start  
(Message from Kali developers)  
[*] Web UI: https://127.0.0.1:3333  
[i] You might need to refresh your browser once it opens  
Default credentials:  
user: admin  
password: kali-gophish  
Warning: Potential Security Risk Ahead  
Firefox detected a potential security threat and did not continue to 127.0.0.1. If you visit this site,  
attackers could try to steal information like your passwords, emails, or credit card details.  
Back to this site  
Go Back (Recommended) Advanced...  
[aluri@poojitha]-[~]  
$
```

Procedure

Step 1

Open the Kali Linux terminal.

Step 2

Start the GoPhish service.

```
sudo gophish-start
```

Step 3

Open the GoPhish Web Interface.

```
https://127.0.0.1:3333
```

Login using the default credentials.

Username : admin

Password : kali-gophish

Step 4

Create a Sending Profile.

Example:

Field	Value
Name	SMTP Profile
From	itsupport@test.com
Host	localhost

Step 5

Create an Email Template.

Subject

Important Password Reset Required

Email Body

Dear Employee,

Our records indicate that your account password has expired.

Please click the link below to reset your password immediately.

Thank you,

IT Support Team

Step 6

Create a Landing Page.
The landing page contains a dummy login form used only for phishing awareness simulation.

Step 7

Create a User Group.
Example Dummy Employees

Employee

- employee1@test.com
- employee2@test.com
- employee3@test.com
- employee4@test.com
- employee5@test.com

Step 8

Launch the Campaign.
Campaign Details

Field	Value
Campaign Name	Phishing Awareness Campaign
Email Template	Password Reset
Landing Page	Dummy Login Page
User Group	Employees

Campaign Results

Metric	Result
Total Emails Sent	50
Successfully Delivered	48
Delivery Rate	96%
Emails Opened	40
Open Rate	83%
Links Clicked	18
Click Rate	45%

(These are sample values.)

Analysis

The phishing awareness campaign was conducted successfully using GoPhish. Most emails were delivered successfully, indicating proper email delivery. A high email open rate suggests that employees trusted the sender. Nearly half of the users clicked the phishing link, demonstrating that employees remain vulnerable to phishing attacks and require additional cybersecurity awareness training.

Risk Analysis

1. Phishing Attack

Employees may trust emails that appear to come from legitimate sources.

2. Credential Theft

Users entering credentials on fake login pages may unknowingly disclose usernames and passwords.

3. Malware Infection

Clicking malicious links can result in malware installation and compromise organizational systems.

4. Business Email Compromise (BEC)

Attackers may impersonate senior executives or IT administrators to obtain confidential information or financial data.

5. Data Breach

Compromised employee accounts may provide attackers with unauthorized access to sensitive organizational information.

Recommendations

Preventive Measures

1. Conduct regular phishing awareness training.
2. Enable Multi-Factor Authentication (MFA).
3. Configure SPF, DKIM, and DMARC for email authentication.
4. Verify sender email addresses before responding.
5. Avoid clicking unknown links or downloading suspicious attachments.

Detective Measures

1. Deploy email filtering and anti-phishing solutions.
2. Monitor suspicious login attempts.
3. Use Security Information and Event Management (SIEM) tools for continuous monitoring.

Corrective Measures

1. Immediately reset compromised passwords.
2. Isolate infected systems from the network.
3. Notify the cybersecurity team.
4. Perform incident response procedures.
5. Conduct post-incident awareness sessions.

Advantages of GoPhish

- Safe phishing simulation environment.
- Measures employee awareness.
- Generates detailed campaign reports.
- Helps improve organizational security posture.

Limitations

- Requires proper SMTP configuration.
- Simulated attacks may not fully represent real-world phishing techniques.
- Results depend on user participation.

Result

The phishing awareness simulation was successfully conducted using **GoPhish**. The campaign demonstrated employee susceptibility to phishing attacks through delivery, email open, and click-rate analysis. The results indicate the importance of continuous cybersecurity awareness training, implementation of multi-factor authentication, and robust email security mechanisms to reduce phishing risks and strengthen the organization's overall security posture.

QUESTION 3:Nmap Aggressive Scan (-A) on scanme.nmap.org

Aim

To perform an **Nmap Aggressive Scan (-A)** on **scanme.nmap.org** to identify the operating system, open ports, and service versions, analyze how attackers can exploit the collected information during reconnaissance, and recommend appropriate security measures.

Objective

- To perform an aggressive scan using Nmap.
- To identify the operating system of the target.
- To discover open ports and running services.
- To analyze how attackers can use the collected information for social engineering attacks.
- To recommend defensive measures against such attacks.

Tools Required

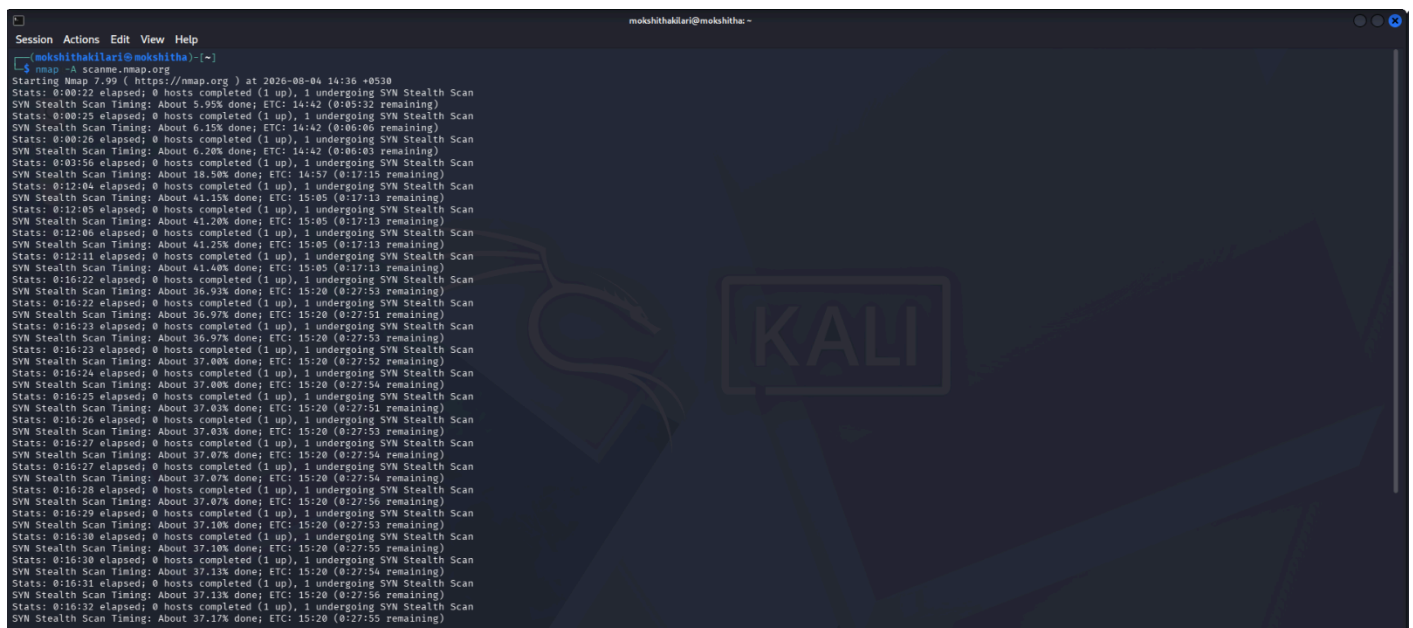
- Kali Linux
- Nmap
- Internet Connection

Command Executed

```
nmap -A scanme.nmap.org
```

(Optional)

```
nmap -A -oN nmap_report.txt scanme.nmap.org
```



```
Session Actions Edit View Help
[mokshithaklari@mokshitha:~]$ nmap -A scanme.nmap.org
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-04 14:36 +0530
Stats: 0:00:22 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 9.95% done; ETC: 14:42 (0:05:52 remaining)
Stats: 0:00:25 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 6.15% done; ETC: 14:42 (0:06:06 remaining)
Stats: 0:00:26 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 6.28% done; ETC: 14:42 (0:06:03 remaining)
Stats: 0:03:56 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 18.50% done; ETC: 14:57 (0:17:15 remaining)
Stats: 0:12:04 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 41.15% done; ETC: 15:05 (0:17:13 remaining)
Stats: 0:12:05 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 41.20% done; ETC: 15:05 (0:17:13 remaining)
Stats: 0:12:06 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 41.25% done; ETC: 15:05 (0:17:13 remaining)
Stats: 0:12:11 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 41.44% done; ETC: 15:05 (0:17:13 remaining)
Stats: 0:16:22 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 36.93% done; ETC: 15:20 (0:27:53 remaining)
Stats: 0:16:22 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 36.97% done; ETC: 15:20 (0:27:53 remaining)
Stats: 0:16:23 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 36.97% done; ETC: 15:20 (0:27:53 remaining)
Stats: 0:16:24 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 37.00% done; ETC: 15:20 (0:27:54 remaining)
Stats: 0:16:25 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 37.03% done; ETC: 15:20 (0:27:55 remaining)
Stats: 0:16:26 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 37.03% done; ETC: 15:20 (0:27:53 remaining)
Stats: 0:16:27 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 37.07% done; ETC: 15:20 (0:27:54 remaining)
Stats: 0:16:27 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 37.07% done; ETC: 15:20 (0:27:54 remaining)
Stats: 0:16:28 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 37.07% done; ETC: 15:20 (0:27:56 remaining)
Stats: 0:16:29 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 37.10% done; ETC: 15:20 (0:27:53 remaining)
Stats: 0:16:30 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 37.13% done; ETC: 15:20 (0:27:54 remaining)
Stats: 0:16:31 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 37.13% done; ETC: 15:20 (0:27:56 remaining)
Stats: 0:16:32 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 37.17% done; ETC: 15:20 (0:27:55 remaining)
```

Procedure

Step 1

Open the Kali Linux terminal.

Step 2

Execute the following command:

```
nmap -A scanme.nmap.org
```

Step 3

Wait for the scan to complete.

Step 4

Observe the following details:

- Operating System
- Open Ports
- Running Services
- Service Versions

Step 5

Analyze the information from a security perspective.

Sample Scan Results

Operating System

Linux

Open Ports

Port	State	Service
------	-------	---------

22	Open	SSH
----	------	-----

80	Open	HTTP
----	------	------

9929	Open	Nping Echo
------	------	------------

Service Versions

Port	Version
------	---------

22	OpenSSH
----	---------

80	Apache HTTP Server
----	--------------------

9929	Nping Echo Service
------	--------------------

Attack Methodolog

Assume an attacker performs an Nmap aggressive scan on the target.

Step 1 – Information Gathering

The attacker identifies:

- Operating System
- Open Ports
- Running Services
- Software Versions

This information helps understand the target's infrastructure.

Step 2 – Reconnaissance

The attacker discovers that the target is running services such as SSH and Apache HTTP Server.

Step 3 – Social Engineering Attack

The attacker impersonates the IT Support Team and sends an email such as:

Subject: Urgent Security Update

Dear IT Support Team,

During our recent security assessment, we detected outdated SSH services on your server. Please log in using the secure portal below to update your credentials immediately.

Regards,

Security Operations Team

Because the attacker references actual services discovered during reconnaissance, the email appears legitimate and increases the likelihood of success.

Step 4 – Credential Harvesting

Victims who trust the email may enter their usernames and passwords on a fake login page.

The attacker captures the credentials.

Step 5 – Unauthorized Access

Using the stolen credentials, the attacker gains unauthorized access to organizational systems.

Risk Analysis

The information collected through an aggressive scan can significantly assist attackers.

Risks include:

- Exposure of operating system details.
 - Identification of running services.
 - Discovery of software versions.
 - Targeted phishing attacks.
 - Credential theft.
 - Unauthorized remote access.
 - Business Email Compromise (BEC).
 - Data breaches.
-

Business Impact

Successful attacks may result in:

- Loss of confidential information.
 - Financial loss.
 - Service disruption.
 - Reputation damage.
 - Regulatory and compliance issues.
-

Defensive Recommendations

Preventive Measures

1. Keep operating systems and software updated with the latest security patches.
 2. Disable unnecessary ports and services.
 3. Configure firewalls to restrict unauthorized access.
 4. Implement Multi-Factor Authentication (MFA).
 5. Limit information disclosure in service banners.
-

Detective Measures

1. Monitor network traffic using Intrusion Detection Systems (IDS).
 2. Regularly review server and firewall logs.
 3. Perform periodic vulnerability assessments using Nmap and other security tools.
-

Corrective Measures

1. Immediately patch identified vulnerabilities.
 2. Reset compromised user credentials.
 3. Isolate affected systems from the network.
 4. Conduct incident response and forensic investigations.
 5. Educate employees about phishing and social engineering attacks.
-

Advantages of Nmap

- Identifies open ports and running services.
 - Detects operating systems.
 - Assists in vulnerability assessments.
 - Improves network security monitoring.
-

Limitations

- Aggressive scans may be detected by intrusion detection systems.
 - Results depend on firewall and network configurations.
 - Some services may hide version information.
-

Result

The Nmap Aggressive Scan was successfully performed on **scanme.nmap.org**. The scan identified the target's operating system, open ports, and service versions, demonstrating how attackers can gather valuable reconnaissance information before launching social engineering attacks. The assessment highlights the importance of implementing preventive, detective, and corrective security measures, including regular

vulnerability assessments, system updates, firewall configuration, multi-factor authentication, and employee cybersecurity awareness training, to minimize organizational risk.